

What's in the box?!?

How to evaluate the security of OSS dependencies and components

Dave Russo - Community Lead for Standards and Open Source Policy, Red Hat OSAIPO
CRob - CTO & Chief Security Architect - Akrites/OpenSSF/LF

CLE-ISS 2026

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Copyright © 2024 The Linux Foundation®. All rights reserved. The Linux Foundation has registered trademarks and uses trademarks.

Who are these clowns?



Dave Russo

Simple caveman

Professional cat herder

Engineering and security background

Community Lead for Standards and Open Source Policy, Red Hat Open Source & AI Program Office



CRob, n, adj, and v

Pronunciation: U.S. (K-rowb)

```
# chmod 666 crob.md
```

44th level Dungeon Master

27th level Securityologist

Pirate-enthusiast & hat-owner

Chief Technology Officer & Chief Security Architect: Akrites - OpenSSF - Linux Foundation

Disclaimer/ Weasel Words

CRob & Dave are not lawyers.

CRob & Dave certainly are not YOUR lawyers.

These are thoughts, opinions, and insights from our careers; consult YOUR attorney to understand what YOU and YOUR organization needs to be doing.

Joe the Legal Weasel says:



Image Source

We’re from Upstream, we’re here to “help”!

Akrites

www.akrites.org

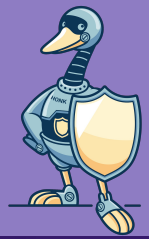
Coordinated, confidential vulnerability remediation for the open source software critical infrastructure depends on.

AKRITES

OpenSSF

www.openssf.org

The Open Source Security Foundation (OpenSSF) is a community of software developers, security engineers, and more who are working together to secure open source software for the greater public good.



OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Eclipse ORC

orcwg.org

The Open Regulatory Compliance (ORC) Working Group unites diverse open source stakeholders, from foundations to small businesses, with policymakers to help projects meet evolving regulatory requirements and ensure the industry can safely leverage open source throughout the software supply chain.



Some context...



OpenSSF
OPEN SOURCE SECURITY FOUNDATION

5

The Hidden Scale of Modern Software



While zero-days are often exploited before or within days of disclosure (median time to exploit under 5 days), the average critical enterprise vulnerability takes more than **70 to 74 days** for organizations to patch. Citation

References:

State of the Software Supply Chain Report, Sonatype
2026 OSSRA Component Growth Findings, Black Duck
Open Source Security and Risk Analysis (OSSRA) Report, Synopsys (Black Duck) Cybersecurity Research Center,
Census II of Open Source Software, Linux Foundation / Harvard Laboratory for Innovation Science

The Regulatory Shift: Compliance is Now Law



EU Cyber Resilience Act

Mandatory CE mark cybersecurity compliance across EU markets

US Executive Order 14028

Enforced NIST SSDF attestation for federal software vendors
(partially rescinded)

CISA Secure by Design

Strict manufacturer accountability for bundled upstream risk

And this is only the beginning...

The Regulatory Shift: CRA Enforcement

€15M Non-Compliance Fines

Penalties up to €15M or 2.5% global annual revenue

24 hour Exploit Disclosure

Mandatory notification timelines for actively exploited vulnerabilities & severe incidents

100% SBOM Obligation

Required machine-readable component catalogs to access EU market



Third-Party Component/Vendor Management



OpenSSF
OPEN SOURCE SECURITY FOUNDATION

9

Be a Responsible Open Source Consumer

Due Diligence

Pre-consumption vetting of licensing, project health, maintenance, & dependencies



Risk Assessment

Continuous tracking of vulnerability exposure and transitive blast radius

Attestations

Cryptographic proof of provenance & pedigree (origin and build lineage), testing, processes, etc.

Verifiable Evidence

Machine-readable SBOMs, automated build logs, & test results

Information Consumers Should Be Looking For

Software Bills of Materials

Because provenance and dependencies are important

Process Documentation

security.md, VM/IR intake and maintenance, contact information

Attestations

Provide information about a snapshot in time (if they exist)



OpenSSF Scorecard

Assess open source projects for security risks through automated checks

Security Insights

Provides a mechanism for projects to report information about their security in a machine-processable way



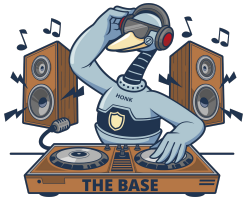
Best Practices Badges

A way for OSS projects to show that they follow good security practices



https://openssf.org/projects/scorecard/
https://openssf.org/projects/security-insights/
https://openssf.org/projects/best-practices-badge/

Open Source Project Security Baseline (ORBIT WG)







Open Resources for Baselines, Interoperability, and Tooling



OSPS Baseline:

- Designed to act as a minimum definition of requirements for a project relative to its maturity level.
- Helps project maintainers understand security best practices and expectations, where their project currently stands, and opportunities for improvement.
- Allows consumers to understand how using the project impacts their security and compliance goals.

Gemara provides a logical model to describe the categories of compliance activities, how they interact, and the schemas to enable *automated interoperability* between them.

Other useful tools include: ***minder***, ***privateer***, ***ampel***, ***darnit***

Launchpad SIG & CRABFOSC



CRA Baseline for Open Source Consumption



CRABFOSC makes due diligence discussable and documentable

Asks a Consistent Set of Questions

What evidence should a manufacturer collect before consuming an OSS component?

Defines Measurable Control Intent

What would count as a meaningful answer, and how can it be evaluated?

Records the Results in a Common Form

How can humans and tools inspect the same decision record?

https://github.com/ossf/orbit-launchpad

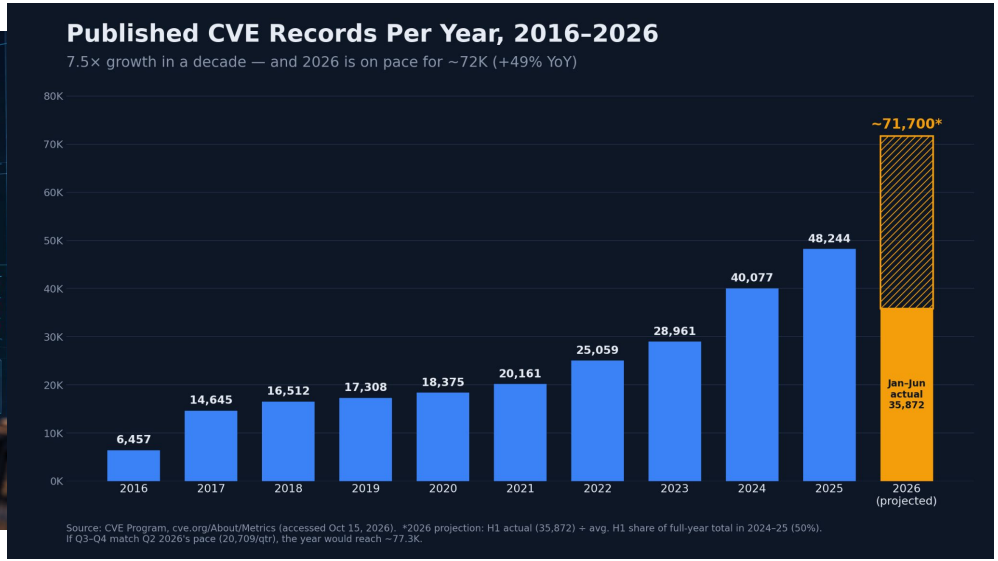
Vulnerability Management



OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Gratuitous CVE-LIST slide for a security conference....





AI Slop, by the numbers

- **Explosive CVE Growth:** Published CVEs increased by **49% to 51% year-over-year** in the first half of 2026, with nearly 36,000 to 37,000 CVEs recorded in H1 alone (arriving at a rate of roughly one every 7.4 minutes). [1, 2, 3]
- HackerOne **Report Volume Surge:** HackerOne reported a **more than 100% increase** in vulnerability submissions after February 2026, driven heavily by AI-assisted tools generating both valid findings and a high volume of unverified or duplicate reports. [4]
- According to CrowdStrike (August 2026), 88% of the exploitation it observed against vulnerabilities with public proof-of-concept code happened within 48 hours of release.
- HackerOne (May 2026) reports a surge of more than 100% in report volume since February 2026, including duplicates and reports nobody could verify.



- In open source cybersecurity, AI is kind of a problem — but it can also be a solution
- AI coding tools run riot over SBOM controls as EU CRA looms

Tips for the Blue Team...

SBOMs (Build, Source, and Runtime) can all help you understand what components are active within your network.

SLSA can be used to help check up on the health of the supply chains for your upstream components.

VEX can be used with your SBOMs to reduce false-positive reports and focus in on the issues that matter most to YOU!

Software consumers MUST becomes **responsible** consumers, performing **due diligence** on the Third Party Components in their environment

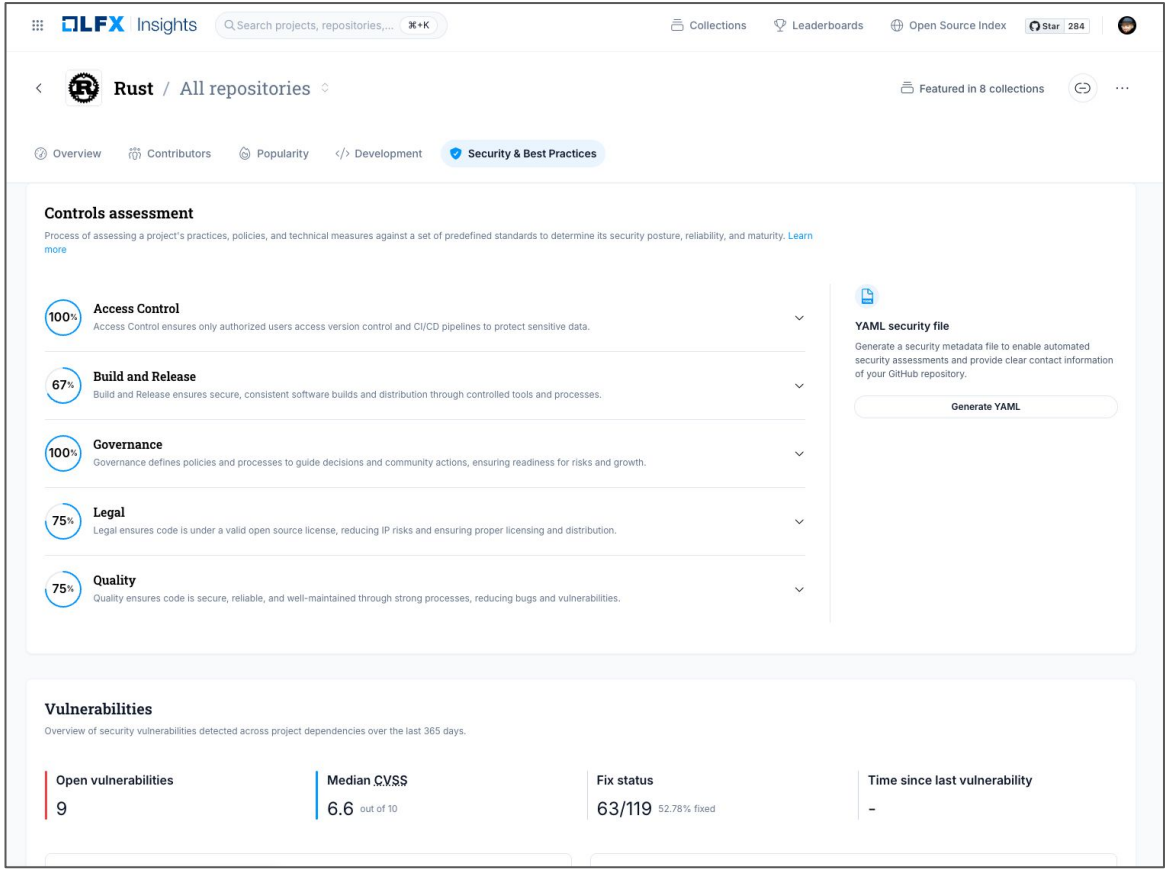


Triage Overload: Security teams are overwhelmed by the sheer volume of automated noise and duplicate bug-bounty submissions.

Remediation Lag: Resolution rates for AI/LLM vulnerabilities lag behind standard software assets, hovering around 38.4% due to complex runtime and configuration dependencies rather than simple code patches.

Inside Insights

Based on the OpenSSF suite of tools, LFX Insights can provide project consumers a wealth of additional information about the projects they use every day, including details about the Security and Best Practices of the team.



Gratuitous AI Slide



OpenSSF
OPEN SOURCE SECURITY FOUNDATION

19

AI has changed, quite literally, EVERY damn thing

Discovery accelerates. Remediation still takes time.

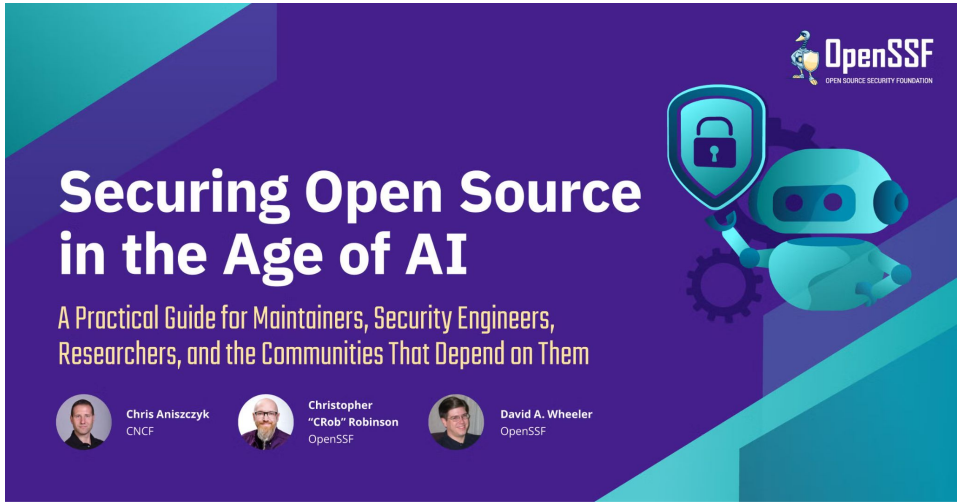
Approximately **2 weeks to patch** high/critical vulnerabilities found by Mythos Preview, according to Anthropic.

Source: Project Glasswing update, May 22, 2026. Program-specific figure—not an industry-wide open-source average.

According to Google Threat Intelligence Group (GTIG) and Mandiant tracking, the mean time to exploit has turned negative, with attackers actively weaponizing and exploiting zero-days an average of **7 days <u>before</u>** public disclosure.



Securing Open Source in the Age of AI



The widespread use of LLMs to find vulnerabilities in all types of software has put intense pressure on both upstream creators and downstream consumers.

There are many great resources that are available for folks to understand the state of the software they are consuming.

How to contribute back



OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Give Back to Your Open Source Upstreams



- Understand the technical debt and cost of private forks*
- Engage with the project on their terms and contribute code, governance, VM/IR, security, testing, etc.
- Dedicated engineer “upstream time”
- Package registries support
- Upstream foundations
- Sponsorship
- “Stewardship”

*OpenSSF 2026 CRA Awareness and Readiness Report: https://openssf.org/resources/publications/2026-cra-awareness-and-readiness-report/

How to Get Involved

Join a working group, SIG, or project:



Open Source Security Foundation (OpenSSF) WGs



Global CyberPolicy WG + SIGs



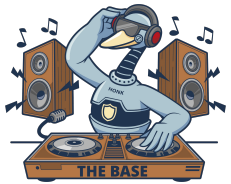
ORBIT WG



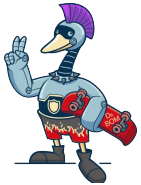
Launchpad SIG



Gemara Project



Definitions SIG *(formerly Baseline SIG)*



SBOM-VEX WG



Vulnerability Disclosures WG



Open Regulatory Compliance (ORC) WG + SIGs

Thank You

Let's think about how we can collaborate to serve our maintainers, our communities, and the ecosystem to address these challenges!







drusso_at_RedHat_dot_com

https://github.com/SecurityCaveman

https://www.linkedin.com/in/david-russo-b0ab27110/

@RedHat

@redhatopen.bsky.social

CRob_at_OpenSSF_dot_org

@~~SecurityCRob~~

@SecurityCRob@infosec.exchange

https://github.com/SecurityCRob

The Security Unhappy Hour,
Chips & Salsa
What's in the SOSS?

https://www.linkedin.com/in/darthcrob/

Legal Notice

Copyright © Akrites®, Open Source Security Foundation®, The Linux Foundation®, & their contributors. The Linux Foundation has registered trademarks and uses trademarks. All other trademarks are those of their respective owners.

Per the OpenSSF Charter, this presentation is released under the Creative Commons Attribution 4.0 International License (CC-BY-4.0), available at <https://creativecommons.org/licenses/by/4.0/>. You are free to:

- Share — copy and redistribute the material in any medium or format for any purpose, even commercially.
- Adapt — remix, transform, and build upon the material for any purpose, even commercially.

The licensor cannot revoke these freedoms as long as you follow the license terms:

- Attribution — You must give appropriate credit , provide a link to the license, and indicate if changes were made . You may do so in any reasonable manner, but not in any way that suggests the licensor endorses you or your use.
- No additional restrictions — You may not apply legal terms or technological measures that legally restrict others from doing anything the license permits.